

AI Master Build Specification 5

Part 5: Authentication & Identity Module Build Prompt

Project: Bidra Platform

Module: Authentication & Identity

Version: 1.0

Objective

Implement the complete Authentication & Identity module for the Bidra platform.

This module provides identity, authentication, authorization and session management for the entire platform.

No other business module should be implemented until this module is complete.

The implementation must follow all specifications contained in Volumes 1 through 11.

Module Scope

The Authentication module owns:

- User Accounts
- Registration
- Login
- Logout
- Email Verification
- Password Management
- Refresh Tokens
- Sessions
- Multi-Factor Authentication (future ready)
- Roles
- Permissions
- Organization Membership
- Invitation Acceptance

- Authentication Audit Logs

This module does **not** own:

- Organizations
 - Campaigns
 - Payments
 - Volunteers
 - Rewards
-

Required Deliverables

Generate:

Backend

Frontend

Database

API

Admin Features

Tests

Documentation

OpenAPI

Audit Logging

Monitoring

Database

Implement the following tables:

Users

UserSessions

RefreshTokens

Roles

Permissions

RolePermissions

UserRoles

OrganizationMembers

EmailVerifications

PasswordResetTokens

AuthenticationAudit

Support:

UUID

Public ID

CreatedAt

UpdatedAt

Soft Delete (where applicable)

Indexes

Foreign Keys

Constraints

User Model

Support:

First Name

Last Name

Email

Password Hash

Profile Photo

Language

Timezone

Country

Mobile number

Email Verified

Last Login

Account Status

Created Date

Updated Date

Deleted Date

Public ID

Users must have globally unique email addresses.

Passwords must never be stored.

Authentication

Implement:

Email Registration

Login

Logout

Refresh Tokens

Token Rotation

Session Revocation

Password Reset

Email Verification

Remember Me

Account Lockout

Inactive Session Cleanup

Support JWT.

Passwords must use Argon2id.

Future Authentication

Design the architecture to support:

Passkeys

Magic Links

Google Login

Microsoft Login

Apple Login

Enterprise SSO

Without requiring major architectural changes.

These providers should remain disabled during the MVP.

Session Management

Support:

Multiple Devices

Session Listing

Session Revocation

Logout Current Device

Logout All Devices

Idle Timeout

Absolute Timeout

Every session should include:

Device

IP Address

Browser

Operating System

Last Activity

Location (optional)

Roles

Create:

Platform Owner

Platform Administrator

Organization Owner

Organization Administrator

Campaign Manager

Volunteer Coordinator

Recognition Partner

Contributor

Volunteer

Guest

Roles should contain permissions.

Permissions must never be hardcoded.

Permissions

Implement granular permissions.

Examples:

campaigns.create

campaigns.publish

campaigns.archive

needs.manage

payments.refund

organizations.verify

users.manage

platform.configure

Permissions should be database-driven.

Organization Membership

Support:

Invitation

Acceptance

Rejection

Removal

Suspension

Member Roles

Multiple Organizations

One user may belong to multiple organizations.

API

Generate:

POST /auth/register

POST /auth/login

POST /auth/logout

POST /auth/refresh

POST /auth/forgot-password

POST /auth/reset-password

POST /auth/verify-email

POST /auth/resend-verification

GET /users/me

PATCH /users/me

GET /users/me/sessions

DELETE /users/me/sessions/{id}

DELETE /users/me/sessions

All endpoints must include OpenAPI documentation.

Frontend

Generate:

Registration Page

Login Page

Forgot Password

Reset Password

Email Verification

Profile Page

Edit Profile

Session Management

Security Settings

Notification Preferences

Privacy Settings

Responsive design is mandatory.

Validation

Validate:

Email

Password Strength

Duplicate Accounts

Password Reset Tokens

Verification Tokens

JWT

Refresh Tokens

Session Ownership

Never trust client validation.

Security

Implement:

JWT

Refresh Tokens

Rotation

Rate Limiting

Password Hashing

Secure Cookies

CSRF Protection (where applicable)

CORS

Helmet

Secure Headers

Authentication Audit Logs

Never expose authentication internals.

Audit Logging

Audit:

Registration

Login

Logout

Failed Login

Password Reset

Password Change

Email Verification

Role Assignment

Permission Changes

Session Revocation

Every authentication event should be traceable.

Notifications

Support:

Welcome Email

Verification Email

Password Reset Email

Password Changed Notification

New Login Alert

Future notifications should be easy to add.

Background Jobs

Queues:

Email

Cleanup Expired Tokens

Cleanup Expired Sessions

Notification Queue

Workers must be idempotent.

Admin Platform

Generate:

User Management

Session Management

Role Management

Permission Management

Authentication Audit Viewer

Account Suspension

Account Reactivation

Password Reset (Admin)

Member Search

Testing

Generate:

Unit Tests

Integration Tests

API Tests

E2E Tests

Security Tests

Examples:

Register

Verify Email

Login

Logout

Refresh Token

Password Reset

Session Revocation

Permission Checks

Documentation

Update:

OpenAPI

Database Documentation

Authentication Documentation

Security Documentation

Architecture Documentation

Administrator Guide

Developer Guide

Acceptance Criteria

The module is complete when:

- ✓ Registration works.
- ✓ Login works.
- ✓ Logout works.
- ✓ Email verification works.
- ✓ Password reset works.
- ✓ Sessions are managed securely.
- ✓ JWT authentication is implemented.
- ✓ Refresh token rotation works.

- ✓ Roles and permissions are database-driven.
 - ✓ Organization membership is supported.
 - ✓ Audit logging captures all authentication events.
 - ✓ Authentication infrastructure is reusable by every other Bidra module.
 - ✓ Tests pass.
 - ✓ Documentation is complete.
-

Final Instruction

This module is the security foundation of the entire Bidra platform.

Implement it with production-quality standards.

Every future module will depend on this implementation.

Favor extensibility, security and maintainability over implementation speed.

Do not proceed to implementing Campaigns, Organizations, Payments or Volunteers until the Authentication & Identity module is fully complete and satisfies all acceptance criteria.